

מודול 1 — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 1: מבוא, מעבדה ומתודולוגיה

2.  פתרונות מלאים — מודול 1

🎯 תרגילים — מודול 1: מבוא, מעבדה ומתודולוגיה

כל התרגילים מתבצעים במעבדה שלך בלבד. הפתרונות המלאים צעד-אחר-צעד נמצאים ב- **solutions.md** — נסה לבד לפני שתציץ!

🚦 לפני שמתחילים — קרא אותי!

- **מה צריך:** מחשב עם **VirtualBox** (מומלץ) או VMware מותקן (ראה מדריך הקמת המעבדה המאויר). בחלק ב' נתקין את Kali — זה בסדר אם זו הפעם הראשונה שלך.
- **איך עובדים:** קרא קודם את ה- **README.md**. לשאלות ידע יש 💡 **רמז** שמפנה לסעיף המתאים; למשימות המעשיות (🟢) **נאמר לך בדיוק מה להקליד ומה לחפש**.
- **נתקעת?** נסה לבד, קרא שוב את הסעיף ב-**README**, ואז הצץ ב- **solutions.md** — יש שם תשובה מלאה לכל תרגיל. אם ההתקנה נכשלת — עבור למדריך המאויר (יש שם פתרון תקלות).
- **זכור:** זה השבוע הראשון. המטרה להכיר ולא לפחד — קח את הזמן.

🌐 איפה לתרגל — שתי דרכים

- **TryHackMe** (בדפדפן, ללא התקנה): “Intro to Offensive Pentesting Fundamentals” · “Security”
- **Kali (מקומי):** התקן מכונת **Kali** (מדריך הקמת המעבדה).

מקרא רמות: 🟢 קל · 🟡 בינוני · 🟠 מתקדם · 🔴 אתגר

חלק א' — שאלות ידע (🟢 קל)

תרגיל 1.1 — מהם שלושת עקרונות ה-CIA Triad? תן דוגמה לפגיעה בכל אחד. 💡 רמז: §1.1 README. ראשי התיבות: **C**onfidentiality, **I**ntegrity, **A**vailability. ✅ הצלחה: שלושת העקרונות + דוגמה לפגיעה בכל אחד (למשל: דלף מידע = פגיעה ב-C).

תרגיל 1.2 — מה ההבדל בין האקר White Hat ל-Grey Hat? 💡 רמז: §1.2 README (טבלת סוגי ההאקרים). ✅ הצלחה: הסברת שההבדל הוא בהרשאה (White = בהרשאה; Grey = ללא הרשאה אך ללא זדון).

תרגיל 1.3 — הסבר במילים שלך את ההבדל בין **Vulnerability**, **Exploit** ו-**Payload**, בעזרת דוגמת "הדלת הנעולה". 💡 רמז: §1.4. Vulnerability = README, Exploit = שיטת הניצול, Payload = מה שרץ אחרי. ✅ הצלחה: שלוש הגדרות ברורות + הדגמה בדוגמת הדלת.

תרגיל 1.4 — מנה את חמשת שלבי ההאקינג האתי בסדר הנכון. 💡 רמז: §1.5 README. מתחיל ב-Reconnaissance ומסתיים ב-Covering Tracks. ✅ הצלחה: חמשת השלבים בסדר: Recon → Scanning → Gaining Access → Maintaining Access → Covering Tracks.

תרגיל 1.5 — לאיזה שלב שייכת כל פעולה? - (א) חיפוש עובד ב-LinkedIn - (ב) הרצת nmap על שרת - (ג) מחיקת קובצי לוג - (ד) הוספת משתמש חדש כדי לחזור מאוחר יותר - (ה) הפעלת Exploit ב-Metasploit 💡 רמז: §1.5 README. שייך כל פעולה לאחד מחמשת השלבים. ✅ הצלחה: א=Recon, ב=Scanning, ג=Covering Tracks, ד=Maintaining Access, ה=Gaining Access.

חלק ב' — הקמת הסביבה (🟡🟢)

בחלק זה נהיה **ישירים** — עקוב אחר הפקודות.

תרגיל 2.1 — התקן את Kali Linux ב-VirtualBox (או VMware), התחבר, ופתח Terminal. 💡 רמז: הורד את קובץ ה-VM המוכן מ-kali.org. משתמש/סיסמה ברירת מחדל: kali / kali. ✅ הצלחה: Kali עלה, התחברת, ויש לך חלון Terminal פתוח.

תרגיל 2.2 — עדכן את Kali בפקודה אחת.

```
sudo apt update && sudo apt full-upgrade -y
```

👁️ **חפש:** שורות של הורדות/עדכונים; בסוף חזרה לשורת הפקודה בלי שגיאות. ✅ הצלחה: העדכון רץ עד הסוף.

תרגיל 2.3 — זהה את כתובת ה-IP הפרטית שלך. 🟡

```
ip a
```

👁️ **חפש:** תחת eth0 — שורת inet עם כתובת כמו 10.0.2.15 או 192.168.x.x. זו הכתובת הפרטית שלך. ✅ הצלחה: רשמת את ה-IP וציינת לאיזה טווח פרטי הוא שייך: 10.x.x.x / 192.168.x.x / 172.31.x – 172.16.x

תרגיל 2.4 🟡 — קח Snapshot של המכונה במצב נקי, ותן לו שם משמעותי. 💡 רמז: ב-VirtualBox: תפריט Machine → Take Snapshot. שם מומלץ: clean-install. ✅ הצלחה: יש Snapshot נקי, ואתה יכול להסביר שהוא מאפשר לחזור אחורה אם משהו יישבר.

חלק ג' — היכרות עם Kali (בינוני) 🟡

תרגיל 3.1 — נווט בתפריט Applications ואתר כלי אחד בכל קטגוריה: Information Gathering, Password Attacks, Exploitation Tools. 💡 רמז: §1.8 README (קטגוריות הכלים). למשל: nmap / hydra / Metasploit. ✅ הצלחה: שם כלי אחד לכל אחת משלוש הקטגוריות.

תרגיל 3.2 — מצא את הקובץ rockyou.txt וספור כמה סיסמאות יש בו.

```
ls -l /usr/share/wordlists/  
sudo gunzip /usr/share/wordlists/rockyou.txt.gz # אם הוא דחוס (.gz)  
wc -l /usr/share/wordlists/rockyou.txt
```

👁️ **חפש:** המספר שמחזיר wc -l (כ-14 מיליון). ✅ הצלחה: מצאת את הקובץ ב-/usr/share/wordlists ויודע כמה שורות בו.

תרגיל 3.3 — לכל קטגוריה, לאיזה שלב מחמשת השלבים היא שייכת? · Information Gathering · Post Exploitation · Exploitation Tools. 💡 רמז: §1.5 + §1.8 README. ✅ הצלחה: Information Gathering=Recon, Exploitation=Gaining Access, Post Exploitation=Maintaining Access

חלק ד' — חשיבה מתודולוגית (מתקדם) 🟠

תרגיל 4.1 — קיבלת בדיקה על "Acme". נתנו לך רק את הדומיין acme.com. (א) איזה סוג בדיקה זה? (ב) איזה פרופיל תוקף אתה מדמה? (ג) מה הפעולה הראשונה שלך, ולאיזה שלב היא שייכת? 💡 רמז: §1.3 README (סוגי בדיקות) + §1.5 (השלבים). ✅ הצלחה: (א) Black Box; (ב) תוקף חיצוני ללא מידע פנים; (ג) Recon פסיבי (למשל OSINT).

תרגיל 4.2 — הלקוח מבקש לבדוק אם עובדים ייפלו בפשינג, ובנוסף לבדוק את שרת ה-Web החיצוני. אילו שני סוגי Engagement אלה? 💡 רמז: §1.3 README (סוגי Engagements). ✅ הצלחה: זיהית Social

תרגיל 4.3 — גילית בטעות שרת שאינו ב-Scope, והוא פגיע מאוד. מה מותר ומה אסור? נמק. 💡 רמז: §1.6 README (היבטים משפטיים, Scope). ✅ הצלחה: אסור לתקוף (מחוץ ל-Scope = ללא הרשאה); מותר ומומלץ לתעד ולדווח ללקוח.

🔴 אתגר מסכם — “תוכנית בדיקה + מעבדה מתועדת”

הפק מסמך קצר (Word/Markdown/צילומי מסך) הכולל:

1. מעבדה מתועדת:

- צילום מסך של Kali פועל עם Terminal.
- פלט `ip a` עם ה-IP הפרטי מסומן.
- פלט `uname -a` (גרסת Kernel).
- הוכחה שלקחת Snapshot.

2. טבלת מתודולוגיה: חמשת השלבים, ולכל שלב — מטרה במשפט + כלי אחד + דוגמה.

3. **תרחיש:** בהינתן בדיקת חדירות Black Box על `acme.com`, כתוב תוכנית פעולה בת 5 שורות — שורה לכל שלב.

4. **הצהרת אתיקה:** פסקה שמסבירה מדוע המעבדה שלך מבודדת, ואילו מסמכים משפטיים נדרשים לפני בדיקה אמיתית.

💡 רמז: כל התשובות כבר בתרגילים 1.1–4.3. רק ארגן אותן למסמך אחד. ✅ הצלחה: מסמך מסודר עם ארבעת החלקים, כולל צילומי המסך של המעבדה.

🍰 שמור את המסמך — זהו ה"תיק" הראשון שלך, והבסיס לכל שאר הקורס.

✅ רשימת בקרה — לפני מעבר למודול 2

- ◻ אני מבין את ה-CIA Triad ומכיר את סוגי ההאקרים והבדיקות
- ◻ אני יודע להסביר Vulnerability / Exploit / Payload
- ◻ אני יכול לדקלם את חמשת השלבים בסדר הנכון
- ◻ Kali מותקן, מעודכן, מבודד ברשת, ויש Snapshot נקי

- ☐ אני יודע לפתוח Terminal ולמצוא כלים ו-wordlists
- ☐ קראתי והבנתי את ההיבטים המשפטיים

הפתרונות המלאים: `solutions.md`

פתרונות מלאים — מודול 1

נסה לפתור לבד ב- `missions.md` לפני שתקרא כאן. הפתרונות מפורטים צעד-אחר-צעד.

חלק א' — שאלות ידע

פתרון 1.1 — CIA Triad - Confidentiality (סודיות): רק מורשים רואים מידע. **פגיעה:** דלף מסד נתונים של סיסמאות. **Integrity (שלמות):** המידע אינו משתנה ללא הרשאה. **פגיעה:** שינוי סכום בהעברה בנקאית. - **Availability (זמינות):** המערכת זמינה. **פגיעה:** מתקפת DoS שמפילה את השרת.

פתרון 1.2 — White Hat vs Grey Hat פועל **בהרשאה מלאה** ובחזרה. Grey Hat פועל **ללא הרשאה** אך לרוב ללא כוונת זדון (למשל מוצא חולשה במערכת של אחר ומדווח עליה) — אך עצם הפעולה ללא רשות היא **בלתי חוקית**.

פתרון 1.3 — Vulnerability / Exploit / Payload - Vulnerability = הפגם. **דלת עם מנעול פגום.** - **Exploit** = ניצול הפגם. **שיטת פריצת המנעול.** - **Payload** = מה שקורה אחרי. **מה שאתה עושה בפנים** — **גונב/מצלם**. נוסחה: **Vulnerability + Exploit + Payload = גישה**.

פתרון 1.4 — חמשת השלבים (בסדר) 1. Reconnaissance (איסוף מידע) 2. Scanning & Enumeration (סריקה ומיפוי) 3. Gaining Access (השגת גישה) 4. Maintaining Access (שמירת גישה) 5. Covering Tracks (טשטוש עקבות)

פתרון 1.5 — שיוך פעולות לשלבים - (א) **Reconnaissance** → LinkedIn (פסיבי) - (ב) **Scanning** → nmap **& Enumeration** - (ג) מחיקת לוגים → **Covering Tracks** - (ד) הוספת משתמש לחזרה → **Maintaining Access** - (ה) **Exploit** ב-Metasploit → **Gaining Access**

חלק ב' — הקמת הסביבה

פתרון 2.1 — התקנה עקוב אחר סעיף 1.7 ב-`README` (או המדריך המאויר). לאחר `Start` (הפעלת המכונה ב-VirtualBox), התחבר עם `kali / kali`. פתח Terminal מסרגל הכלים או בקיצור `Ctrl+Alt+T`.

```
sudo apt update && sudo apt full-upgrade -y
```

`update` מרענן את רשימת החבילות; `full-upgrade` מתקין את הגרסאות החדשות. הזן את הסיסמה `kali` כשתבקש.

פתרון 2.3 — זיהוי IP

```
ip a
```

חפש את השורה `inet` תחת המתאם (למשל `eth0`), למשל:

```
inet 192.168.152.130/24
```

- `192.168.x.x` → שייך לטווח הפרטי **192.168.0.0/16**.
- (אם קיבלת `10.x.x.x` → טווח **10.0.0.0/8**; אם `172.16–31.x.x` → **172.16.0.0/12**).

פתרון 2.4 — Snapshot ב-VirtualBox: `Machine` → `Take Snapshot`, שם: `Kali-clean-install`. **למה חשוב:** אם תקיפה/עדכון ישברו את המערכת, אפשר לחזור למצב תקין בשנייה במקום להתקין מחדש.

חלק ג' — היכרות עם Kali

פתרון 3.1 — כלים לפי קטגוריה דוגמאות תקינות: `Information Gathering` → `nmap`; `Password Attacks` → `metasploit` → `hydra` / `john`; `Exploitation Tools` (כל כלי מהקטגוריה נכון).

פתרון 3.2 — rockyou.txt

```
ls -lh /usr/share/wordlists/
# אם דחוס:
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
wc -l /usr/share/wordlists/rockyou.txt
```

התוצאה: **14,344,392** סיסמאות (בגרסה הסטנדרטית). זהו ה-`wordlist` המפורסם ביותר לתקיפת סיסמאות.

פתרון 3.3 — קטגוריה → **שלב** - `Information Gathering` → `2-1` **שלב** - `Exploitation (Recon / Scanning)` → `3` **שלב** - `Post Exploitation (Gaining Access)` → `4` **שלב** - `Maintaining Access` ולאחר-פריצה `Tools`

חלק ד' — חשיבה מתודולוגית

פתרון 4.1 — תרחיש Acme - (א) Black Box — קיבלת מידע מינימלי בלבד (רק דומיין). - (ב) פרופיל: **תוקף חיצוני ללא פרטי גישה**. - (ג) פעולה ראשונה: **איסוף מידע פסיבי** (WHOIS, תת-דומיינים, OSINT) — שלב 1, Reconnaissance. לא קופצים ישר לסריקה.

פתרון 4.2 — סוגי Engagement - בדיקת עובדים בפישנינג → **Social Engineering**. - בדיקת שרת web חיצוני → **External Network / Web Application**.

פתרון 4.3 — שרת מחוץ ל-Scope אסור לתקוף אותו — הוא מחוץ ל-Scope, ותקיפתו אינה מורשית (ועלולה להיות עבירה פלילית / הפרת חוזה). **מותר ומומלץ** לתעד את הממצא ולדווח ללקוח שהנכס קיים ונראה פגיע, ולהמליץ להוסיפו ל-Scope בבדיקה נפרדת.

אתגר מסכם — קווים מנחים לפתרון

מסמך מלא ייכלול: 1. **מעבדה:** צילומי מסך של Kali + `ip a` (IP פרטי מסומן) + `uname -a` + Snapshot. 2. **טבלת מתודולוגיה:** למשל —

שלב	מטרה	כלי	דוגמה
Recon	איסוף מידע	hunter.io	מציאת מיילים
Scanning	מיפוי שירותים	nmap	<code>nmap -sV target</code>
Gaining Access	ניצול	Metasploit	הפעלת exploit
Maintaining	שמירת גישה	ssh-key	הוספת מפתח
Covering Tracks	ניקוי	—	מחיקת לוגים

3. **תוכנית Black Box ל-acme.com:** שורה לכל שלב (Recon פסיבי → סריקת nmap → ניצול חולשה → שתילת גישה → ניקוי + דוח).

4. **אתיקה:** המעבדה מבודדת (NAT/Host-Only) כדי לא לפגוע ברשת אמיתית; מסמכים נדרשים: Scope, RoE, NDA, מכתב הרשאה.

אם כיסית את כל אלה — עברת את המודול בהצלחה. המשך למודול 2.